

UNIVERSIDAD NACIONAL

Escuela de Informática

Curso: Administración de Bases de Datos (EIF402)

Proyecto Integrador (Parte 1)

Aplicación Web para la Evaluación del Riesgo en la Administración de Bases de Datos Basada
en ISO/IEC 27002

Documento de Diseño de la Solución

Integrantes:

Sebastián Garro Granados
Jostin Jiménez Alfaro
Alejandro Calderón Campos
José Castro

Fecha de entrega: 6 de agosto de 2026

1. Introducción

Este documento describe cómo se va a construir la solución, a partir de lo definido en los dos documentos anteriores: los 20 controles de ISO/IEC 27002 seleccionados, el instrumento de evaluación de 100 preguntas, y las metodologías de cálculo de madurez y de riesgo. Aquí se presenta la arquitectura general del sistema, sus módulos funcionales, el flujo de uso pensado para el auditor, y una vista conceptual del modelo de datos.

El detalle técnico del modelo de datos (diagrama entidad-relación, modelo relacional y diccionario de datos) se presenta en un documento aparte, ya que responde a un entregable distinto dentro del proyecto.

2. Arquitectura General de la Solución

2.1 Enfoque

La aplicación se va a construir como una aplicación web de tres capas: una capa de presentación, donde el auditor responde el cuestionario y consulta los reportes; una capa de lógica de negocio, donde viven las reglas de cálculo de madurez y riesgo; y una capa de datos, la base de datos relacional donde se guarda todo lo relacionado con organizaciones, controles, preguntas, respuestas y resultados.

2.2 Tecnologías seleccionadas

El equipo decidió usar Spring Boot (Java) para el backend, porque ofrece un manejo directo de la persistencia con JPA/Hibernate y facilita mantener separada la lógica de cálculo del resto de la aplicación. Para el frontend se va a usar React, y para la base de datos, MySQL. El backend expone su funcionalidad al frontend mediante una API REST.

Capa	Responsabilidad y tecnología
Presentación	Interfaz donde el auditor inicia sesión, responde el cuestionario, y consulta los paneles, gráficos y mapas de calor de resultados. Construida en React.
Lógica de negocio	Expone una API REST y contiene las reglas de cálculo de madurez y de riesgo definidas en el documento de instrumento y metodologías (secciones 4 y 5). Construida en Spring Boot (Java).
Datos	Base de datos relacional donde se guardan las organizaciones, usuarios, auditorías, el catálogo fijo de 20 controles y 100 preguntas, las respuestas registradas y los resultados calculados. Construida en MySQL.

3. Módulos Funcionales del Sistema

1. Gestión de organizaciones y usuarios: permite registrar las organizaciones que se van a auditar, y los usuarios del sistema (auditores y DBA), con su información básica.
2. Gestión de auditorías: permite crear una nueva auditoría sobre una organización (área evaluada, auditor a cargo, DBA de contraparte, fecha), guardar el avance de una auditoría que quedó a medias, y continuarla después.
3. Cuestionario de evaluación: presenta las 100 preguntas del instrumento organizadas por dominio y control, permite registrar la respuesta (Sí/No/N-A) y la evidencia de cada una.
4. Motor de cálculo: al finalizar una auditoría, aplica la regla de madurez (sección 4 del documento de instrumento y metodologías) a cada control, y las fórmulas de riesgo (sección 5 del mismo documento) para obtener la exposición C, I, D y el índice general.
5. Reportes e indicadores: genera el panel ejecutivo, los gráficos por dominio, el gráfico comparativo de C/I/D, los mapas de calor y los rankings de controles definidos en la sección 6 del documento de instrumento y metodologías.

4. Flujo General de Uso

1. El auditor inicia sesión en el sistema.
2. Selecciona la organización a evaluar (o la registra, si es la primera vez) y crea una nueva auditoría, indicando el área evaluada, el DBA de contraparte y la fecha.
3. El sistema presenta el cuestionario de 100 preguntas, organizado por dominio y control.
4. El auditor va respondiendo cada pregunta (Sí/No/N-A) y anota la evidencia correspondiente; puede guardar el avance en cualquier momento y continuar la auditoría después.
5. Al marcar la auditoría como finalizada, el sistema calcula automáticamente el nivel de madurez y el cumplimiento de cada control, la exposición al riesgo de C, I y D, y el índice general.
6. El sistema genera el panel ejecutivo, los gráficos, los mapas de calor y los rankings de controles críticos.
7. El auditor puede exportar el reporte ejecutivo y, en auditorías futuras sobre la misma organización, comparar los resultados para dar seguimiento a la mejora continua.

5. Vista Conceptual del Modelo de Datos

A nivel conceptual, sin entrar todavía en el detalle técnico de tipos de datos y llaves (que se presenta en el documento de modelo de datos), el sistema necesita llevar información sobre:

- Organización: la entidad que se está auditando.
- Usuario: las personas que usan el sistema, con su rol (auditor, DBA o administrador).
- Auditoría: una evaluación puntual sobre una organización, en una fecha determinada.
- Control: los 20 controles fijos de ISO/IEC 27002 ya seleccionados, con su peso y su relación con C, I y D.
- Pregunta: las 100 preguntas del instrumento, 5 por control.
- Respuesta: lo que contesta el auditor a cada pregunta, dentro de una auditoría específica.
- Resultado por control, por dominio y general de la auditoría: los valores de madurez, cumplimiento y riesgo ya calculados.

Una organización puede tener muchas auditorías a lo largo del tiempo, lo que permite el seguimiento histórico que se planteó como posible mejora del proyecto. Cada auditoría reúne las respuestas a las 100 preguntas del instrumento, y de esas respuestas se derivan los resultados calculados por control, por dominio y generales de esa auditoría en particular.

6. Trazabilidad entre los Documentos del Proyecto

La siguiente tabla resume cómo se conecta cada documento del proyecto con una parte concreta del sistema, para dejar claro que los tres documentos son consistentes entre sí y no piezas sueltas:

Documento	Contenido que aporta	Dónde se usa en el sistema
Investigación, Marco Teórico y Selección de Controles	20 controles ISO/IEC 27002, su dominio, peso y relación con C, I y D.	Catálogo fijo de controles cargado en la base de datos; ponderaciones usadas por el motor de cálculo.
Instrumento de Evaluación y Metodologías de Madurez y Riesgo	100 preguntas del cuestionario y las fórmulas de madurez, cumplimiento y riesgo.	Módulo de cuestionario (captura de respuestas) y módulo de cálculo (motor de madurez y riesgo).
Documento de Diseño de la Solución (este documento)	Arquitectura, módulos funcionales y flujo de uso del sistema.	Estructura del backend y del frontend, y el contrato de la API REST entre ambos.

7. Cierre

Con la arquitectura, los módulos y el flujo de uso definidos acá, el siguiente paso es formalizar el modelo de datos: el diagrama entidad-relación, el modelo relacional y el diccionario de datos, y a partir de ahí empezar la implementación del backend y del frontend.